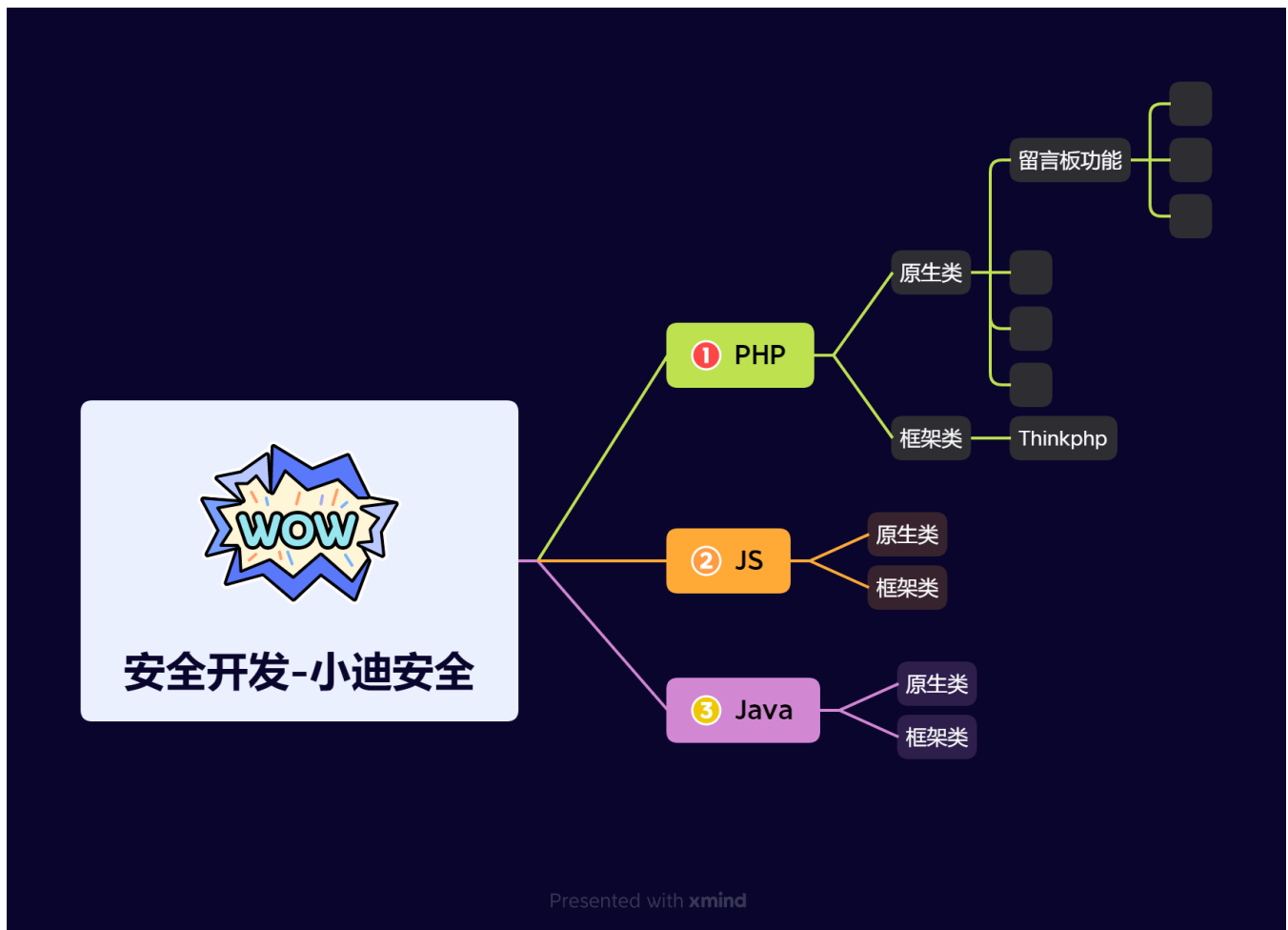


Day39 安全开发-JavaEE应用&SpringBoot框架&Actuator监控泄漏&Swagger自动化



1.知识点

- 1、PHP留言板前后端功能实现
- 2、数据库创建&架构&增删改查
- 3、内置超全局变量&HTML&JS混编
- 4、第三方应用插件&传参&对象调用

-
- 1、PHP后台身份验证模块实现
 - 2、Cookie&Session技术&差异
 - 3、Token数据包唯一性应用场景
 - 项目1：用cookie做后台身份验证
 - 项目2：用session做后台身份验证
 - 项目3：用token做用户登录判断
-

- 1、PHP文件管理-显示&上传功能实现
 - 2、文件上传-\$_FILES&过滤机制实现
 - 3、文件显示-目录遍历&过滤机制实现
-

- 1、PHP文件管理-下载&删除功能实现
 - 2、PHP文件管理-编辑&包含功能实现
-

- 1、PHP新闻显示-数据库操作读取显示
 - 2、PHP模版引用-自写模版&Smarty渲染
 - 3、PHP模版安全-RCE代码执行&三方漏洞
-

- 1、TP框架-开发-路由访问&数据库&文件上传&MVC模型
 - 2、TP框架-安全-不合规写法&内置过滤绕过&版本安全漏洞
-

- 1、JS应用-原生态开发&第三库开发
 - 2、JS功能-文件上传&登录验证&商品购买
-

- 1、JS技术-DOM树操作及安全隐患
 - 2、JS技术-加密编码及数据安全调试
-

- 1、NodeJS-开发环境&功能实现
 - 2、NodeJS-安全漏洞&案例分析
 - 3、NodeJS-开发指南&特有漏洞
-

- 1、三方库-JQuery-使用&安全
 - 2、打包器-Webpack-使用&安全
-

- 1、JavaEE-HTTP-Servlet技术
 - 2、JavaEE-数据库-JDBC&Mybatis
-

- 1、JavaEE-JDBC-SQL预编译
 - 2、JavaEE-HTTP-Filter过滤器
 - 3、JavaEE-对象域-Listen监听器
-

- 1、JavaEE-反射机制-开发和安全应用场景
- 2、JavaEE-反射机制-类&成员变量&方法&构造方法操作
- 3、JavaEE-反射机制-安全应用&反射执行&反序列化链相关

-
- 1、JavaEE-反序列化-解释&使用&安全
 - 2、JavaEE-安全-利用链&直接重写方法
 - 3、JavaEE-安全-利用链&外部重写方法

-
- 1、JavaEE-组件安全-Log4j
 - 2、JavaEE-组件安全-Fastjson
 - 3、JavaEE-基本了解-JNDI-API

-
- 1、JavaEE-JNDI注入-RMI&LDAP
 - 2、JavaEE-漏洞结合-FastJson链
 - 3、JavaEE-漏洞条件-JDK版本绕过

-
- 1、JavaEE-SpringBoot-WebAPP&路由
 - 2、JavaEE-SpringBoot-Mybatis&注入
 - 3、JavaEE-SpringBoot-Thymeleaf&SSTI

-
- 1、JavaEE-SpringBoot-监控系统-Actuator
 - 2、JavaEE-SpringBoot-接口系统-Swagger
 - 3、JavaEE-SpringBoot-监控&接口&安全问题
-

2.演示案例

请求方法	端点	描述
GET	/actuator	查看有哪些 Actuator端点是开放的。
GET	/actuator/auditevent	auditevents端点提供有关应用程序审计事件的信息。
GET	/actuator/beans	beans端点提供有关应用程序 bean 的信息。
GET	/actuator/conditions	conditions端点提供有关配置和自动配置类条件评估的信息。
GET	/actuator/configprops	configprops端点提供有关应用程序@ConfigurationPropertiesbean的信息。
GET	/actuator/env	查看全部环境属性，可以看到 SpringBoot 载入哪些 properties，以及 properties 的值（会自动用*替换 key、password、secret 等关键字的 properties 的值）。
GET	/actuator/flyway	flyway端点提供有关 Flyway 执行的数据库迁移的信息。
GET	/actuator/health	端点提供有关应用程序运行状况的health详细信息。
GET	/actuator/heapdump	heapdump端点提供来自应用程序 JVM 的堆转储。(通过分析查看/env端点被*号替换到数据的具体值。)
GET	/actuator/httptrace	httptrace端点提供有关 HTTP 请求-响应交换的信息。（包括用户HTTP请求的Cookie数据，会造成Cookie泄露等）。
GET	/actuator/info	info端点提供有关应用程序的一般信息。
GET	/actuator/integrationgraph	integrationgraph端点公开了一个包含所有 Spring Integration 组件的图。
GET	/actuator/liquibase	liquibase端点提供有关 Liquibase 应用的数据库更改集的信息。
GET	/actuator/logfile	logfile端点提供对应用程序日志文件内容的访问。
GET	/actuator/loggers	loggers端点提供对应用程序记录器及其级别配置的访问。
GET	/actuator/mappings	mappings端点提供有关应用程序请求映射的信息。
GET	/actuator/metrics	metrics端点提供对应用程序指标的访问。
GET	/actuator/prometheus	端点以prometheusPrometheus 服务器抓取所需的格式提供 Spring Boot 应用程序的指标。
GET	/actuator/quartz	quartz端点提供有关由 Quartz 调度程序管理的作业和触发器的信息。
GET	/actuator/scheduledtasks	scheduledtasks端点提供有关应用程序计划任务的信息。
GET	/actuator/sessions	sessions端点提供有关由 Spring Session 管理的应用程序 HTTP 会话的信息。
GET	/actuator/startup	startup端点提供有关应用程序启动顺序的信息。
POST	/actuator/shutdown	shutdown端点用于关闭应用程序。

2.1 SpringBoot-监控系统-Actuator

1

SpringBoot Actuator模块提供了生产级别的功能，比如健康检查，审计，指标收集，HTTP跟踪等，帮助我们监控和管理Spring Boot应用。

2

~开发使用：

3

1、引入依赖

4

<dependency>

5

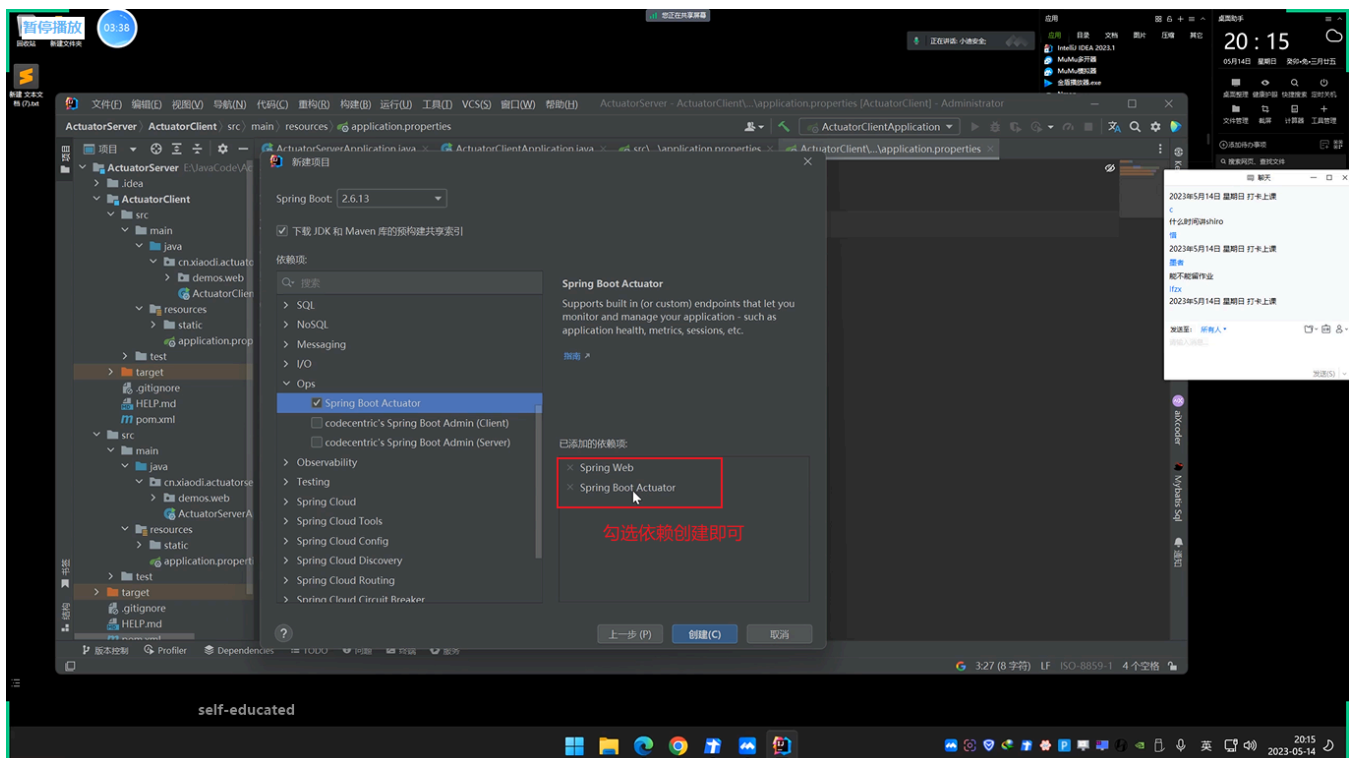
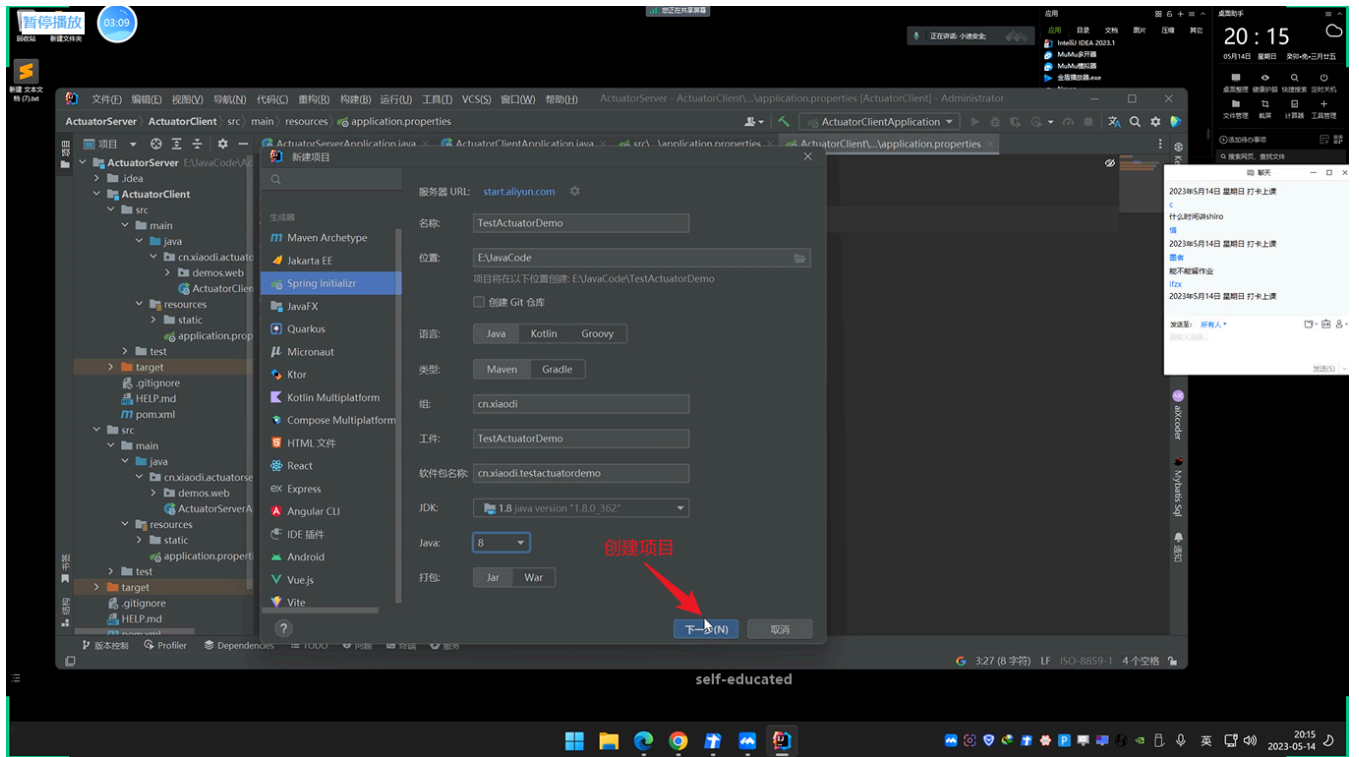
<groupId>org.springframework.boot</groupId>

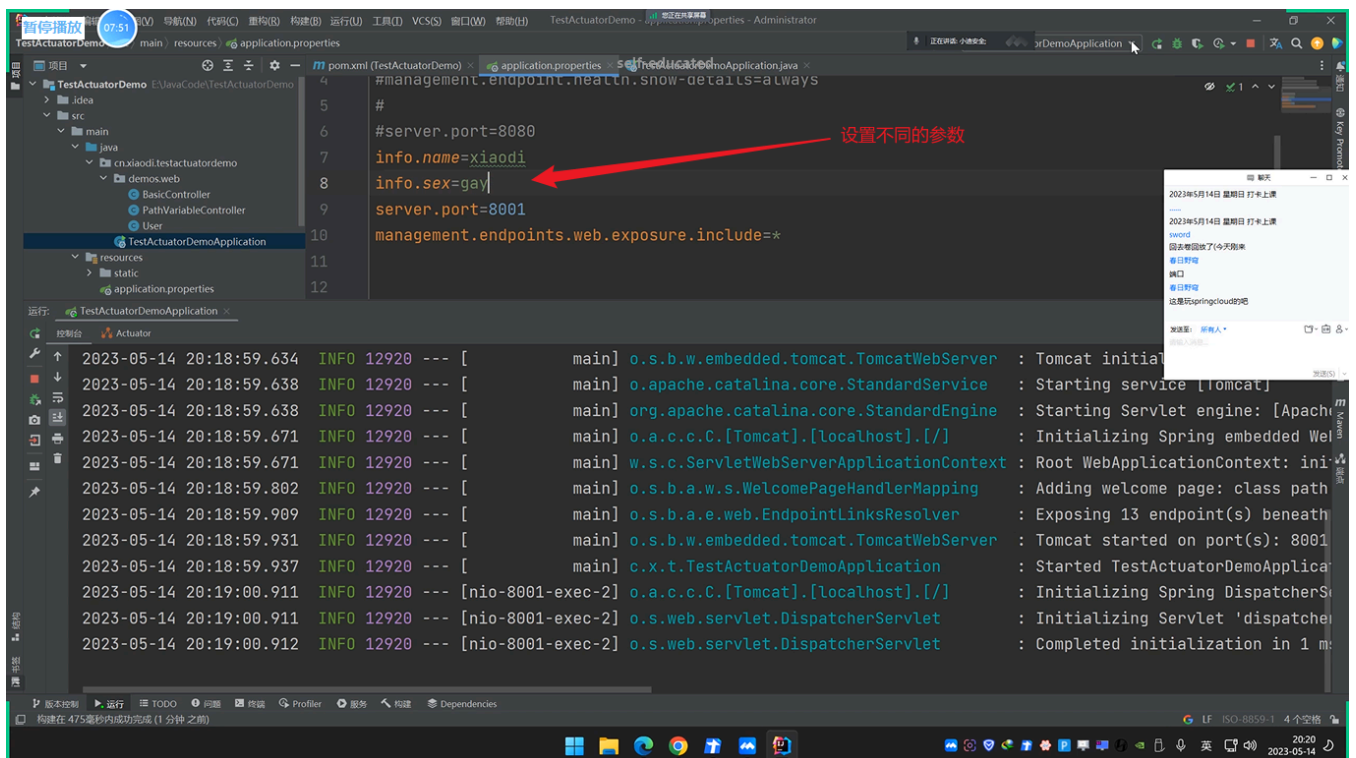
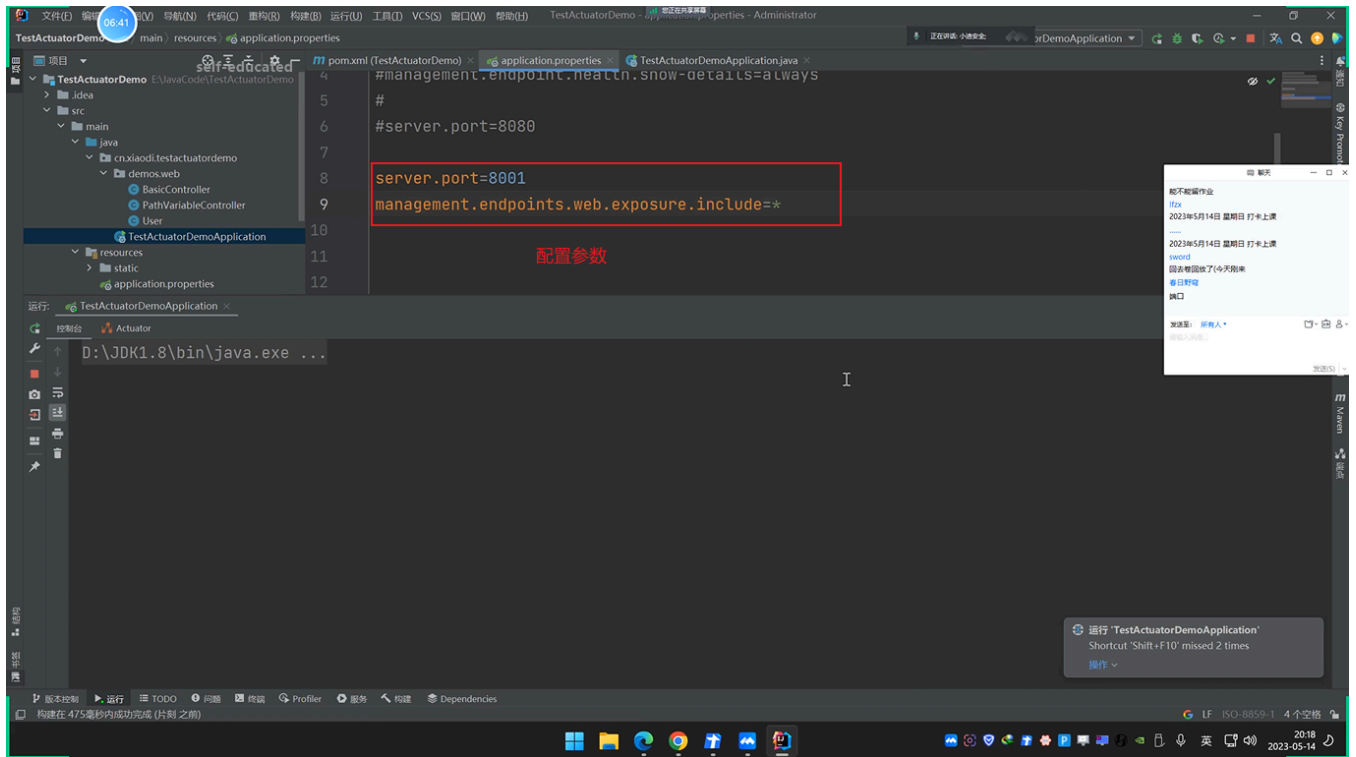
```

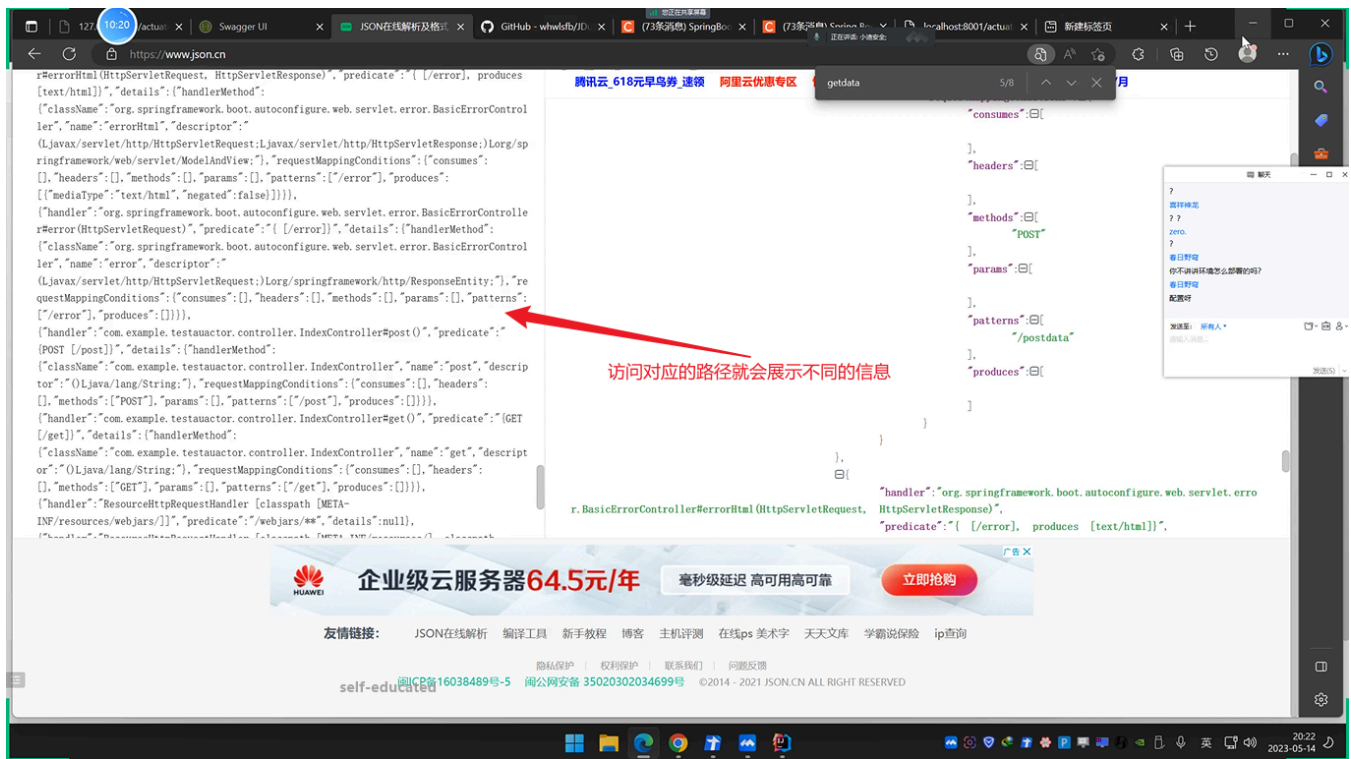
6         <artifactId>spring-boot-starter-actuator</artifactId>
7     </dependency>
8     2、配置监控
9     #暴露
10    #application.properties
11    management.endpoints.web.exposure.include=*
12
13    #application.yml
14    management:
15        endpoints:
16            web:
17                exposure:
18                    include: '*'
19
20    #安全配置:
21    #application.properties
22    management.endpoint.env.enabled=false
23    management.endpoint.heapdump.enabled=false
24
25    #application.yml
26    management:
27        endpoint:
28            heapdump:
29                enabled: false #启用接口关闭
30        env:
31            enabled: false #启用接口关闭
32
33    2、1 图像化Server&Client端界面
34    Server: 引入Server依赖-开启 (@EnableAdminServer)
35    Client: 引入Client依赖-配置 (连接目标, 显示配置等)
36
37    3、安全问题
38    -heapdump泄漏
39    jvisualvm分析器
40    JDumpSpider提取器
41    https://github.com/whwlsfb/JDumpSpider/releases
42    分析提取出敏感信息 (配置帐号密码, 接口信息 数据库 短信 云应用等配置)
43    -其他利用见下文
44    https://blog.csdn.net/dnrnrwfs/article/details/125242990
45    分析得到有一些组件 (不安全的组件, 如log4j)

```

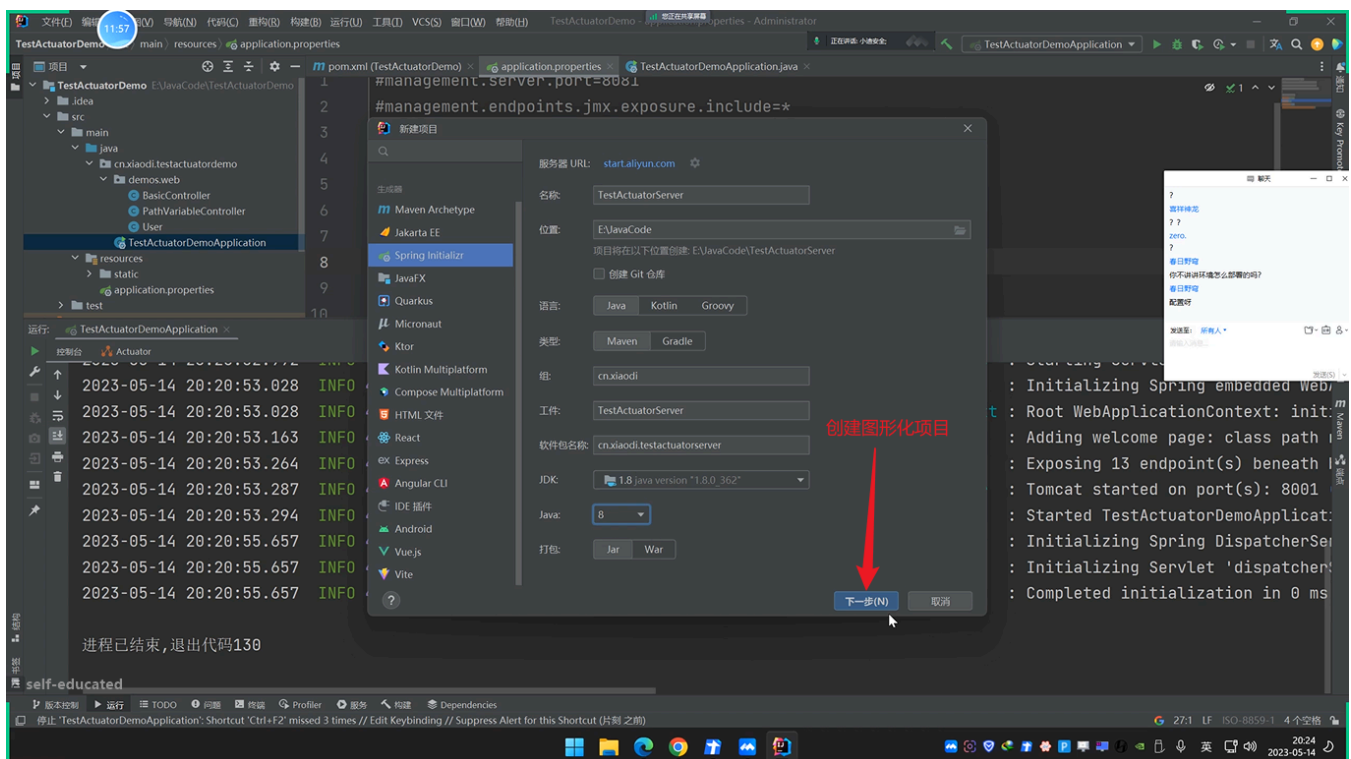
(1) 创建项目:

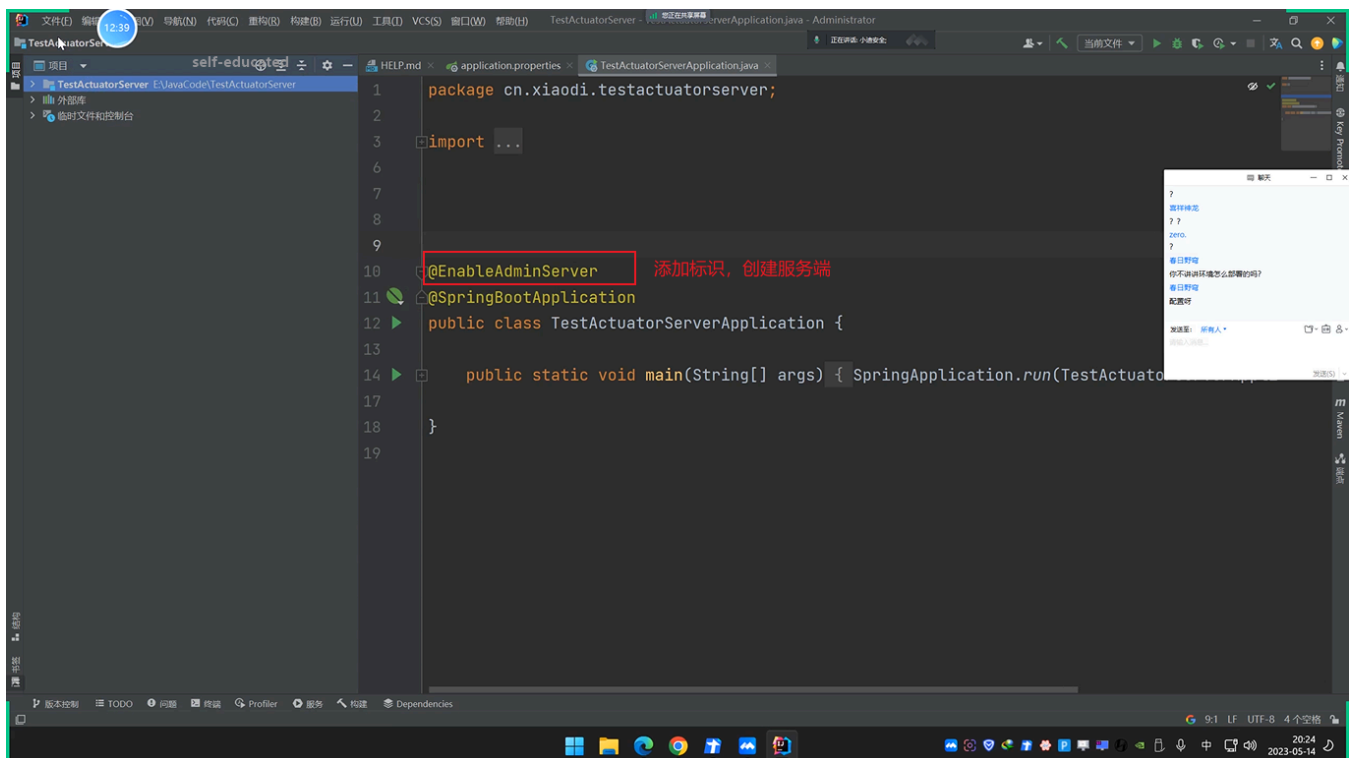
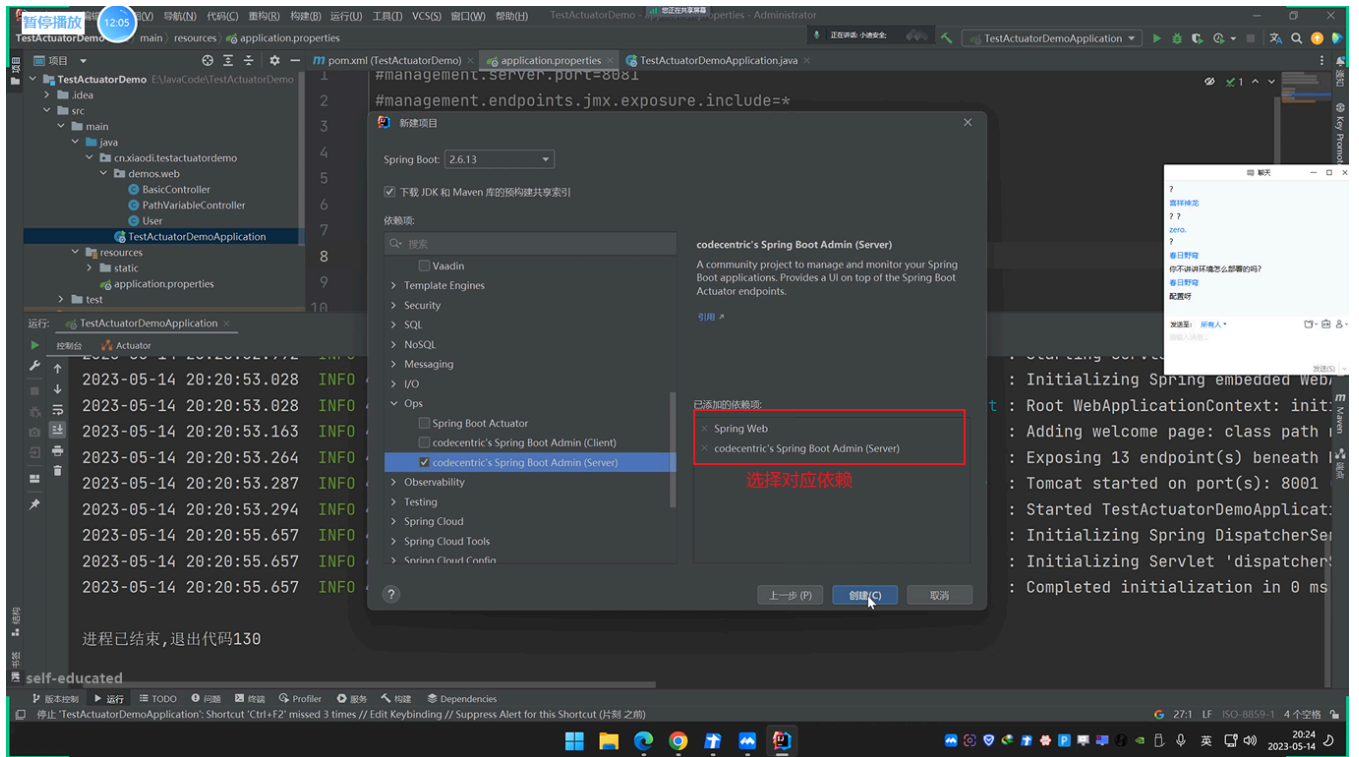


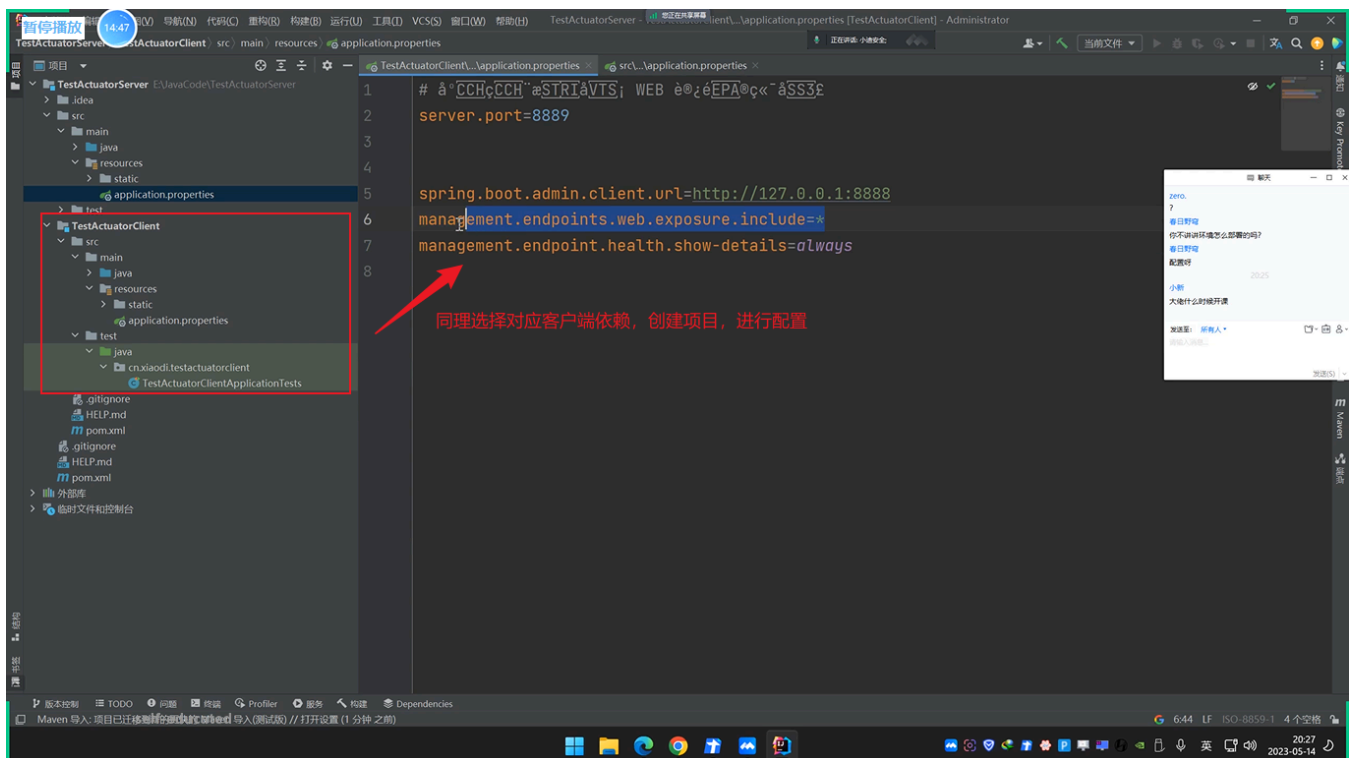
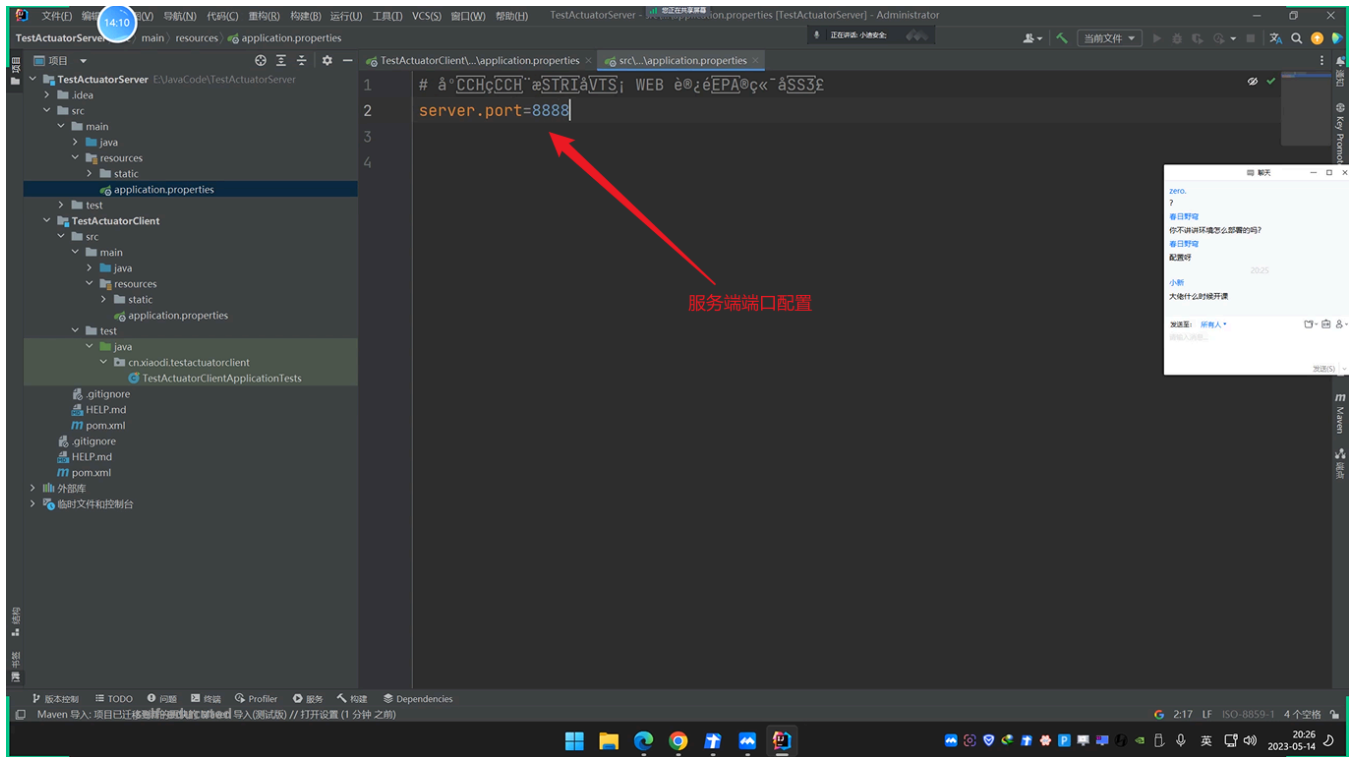


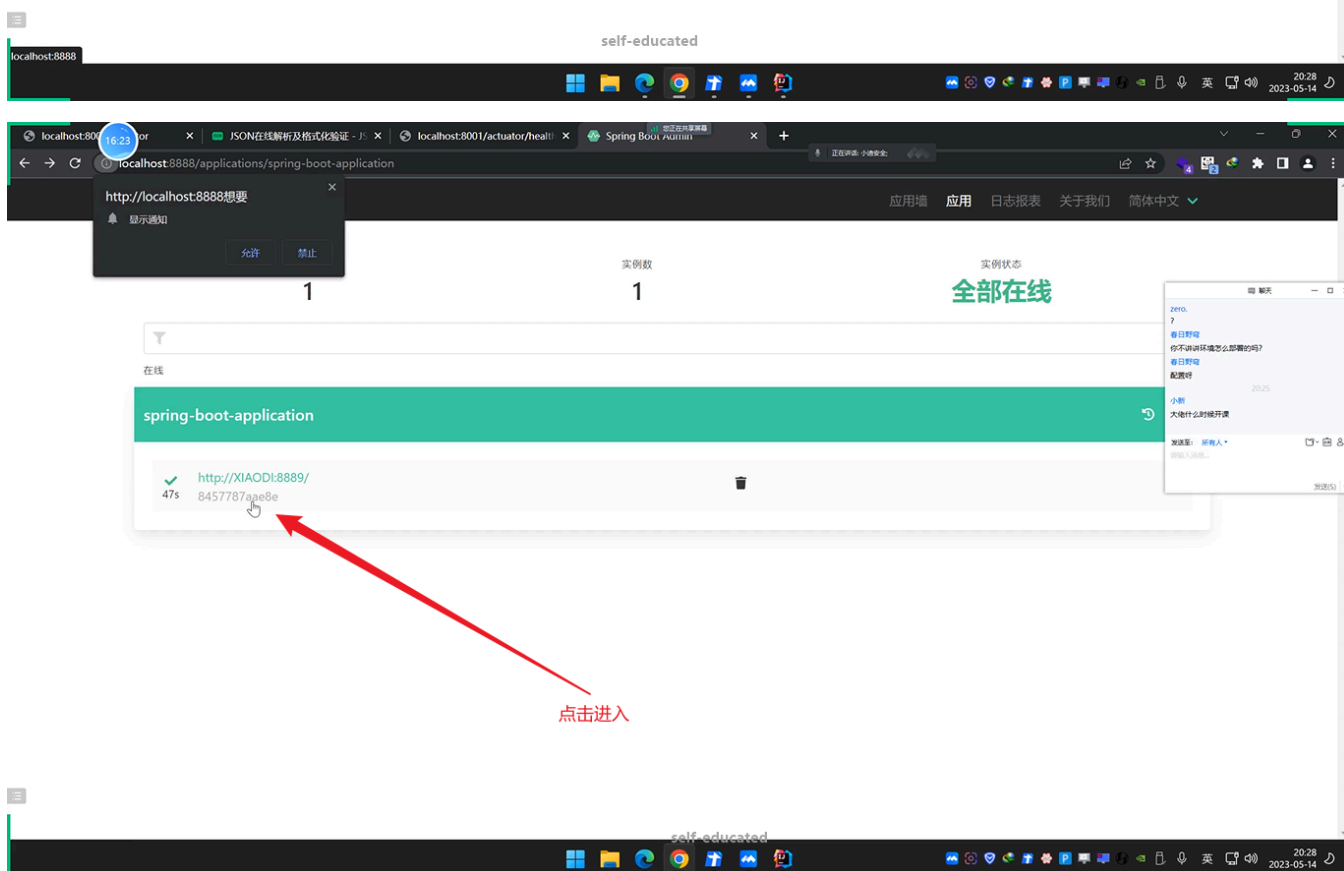
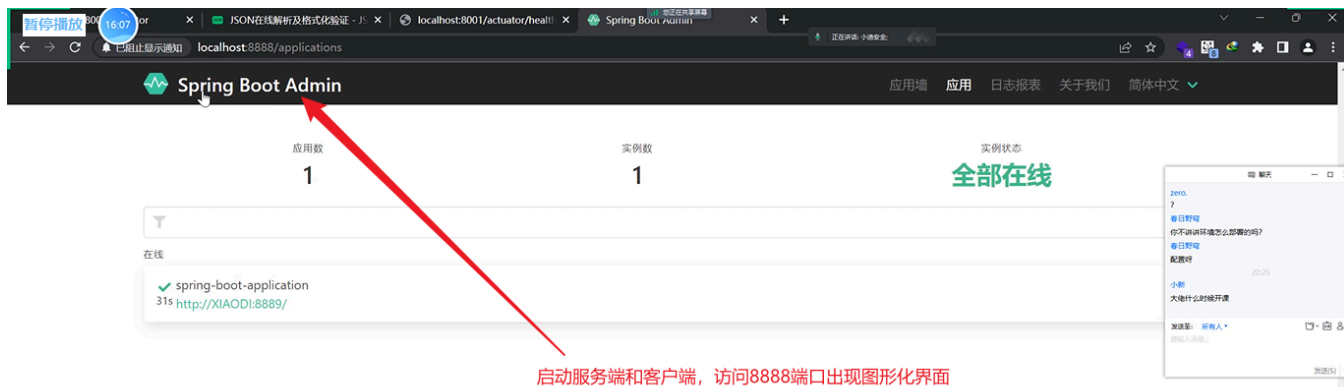


(2) 图像化Server&Client界面:





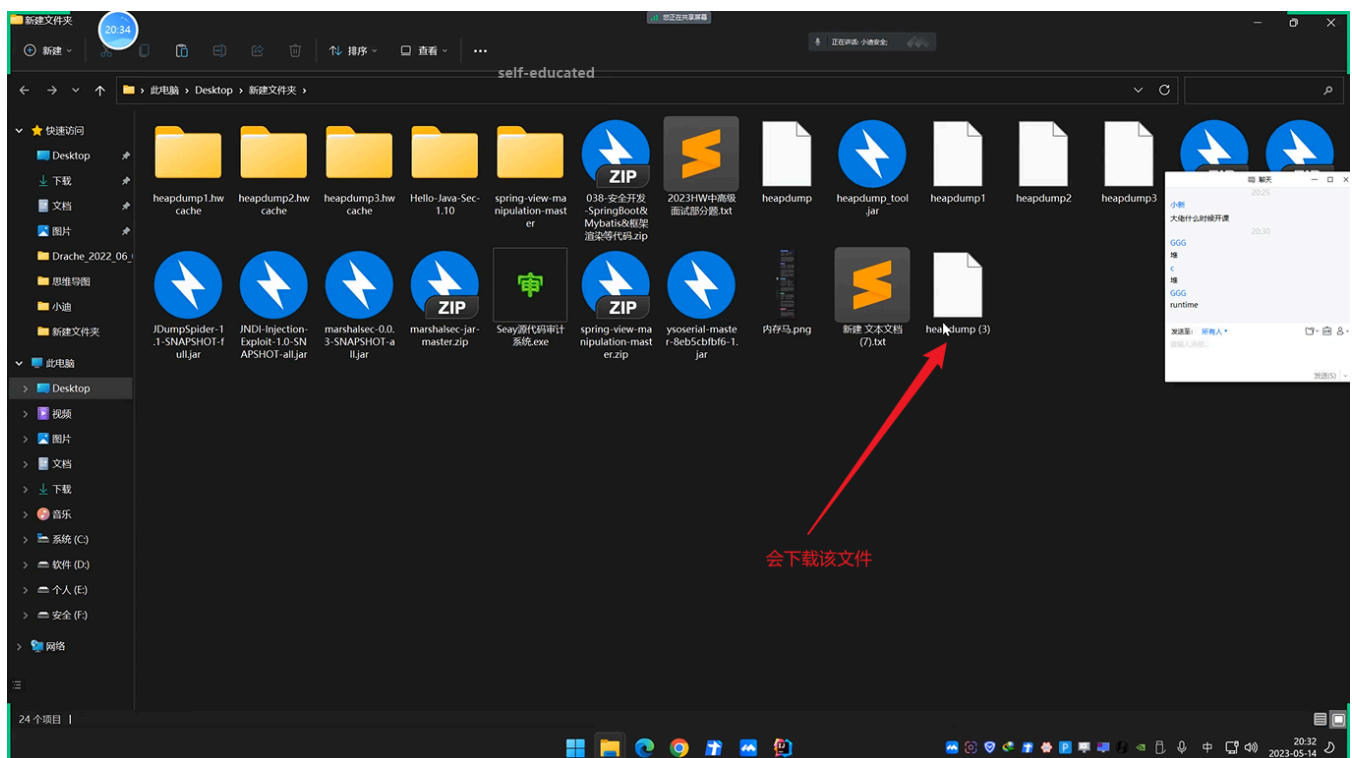
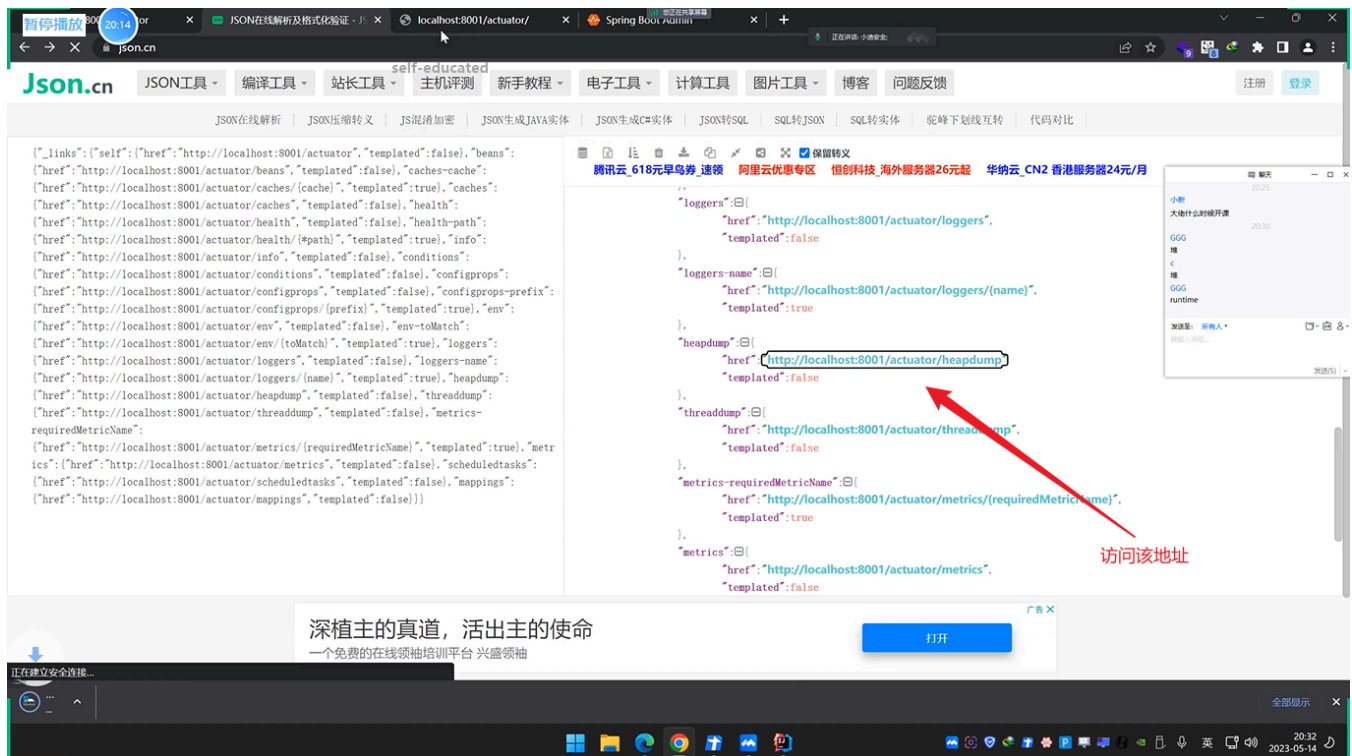




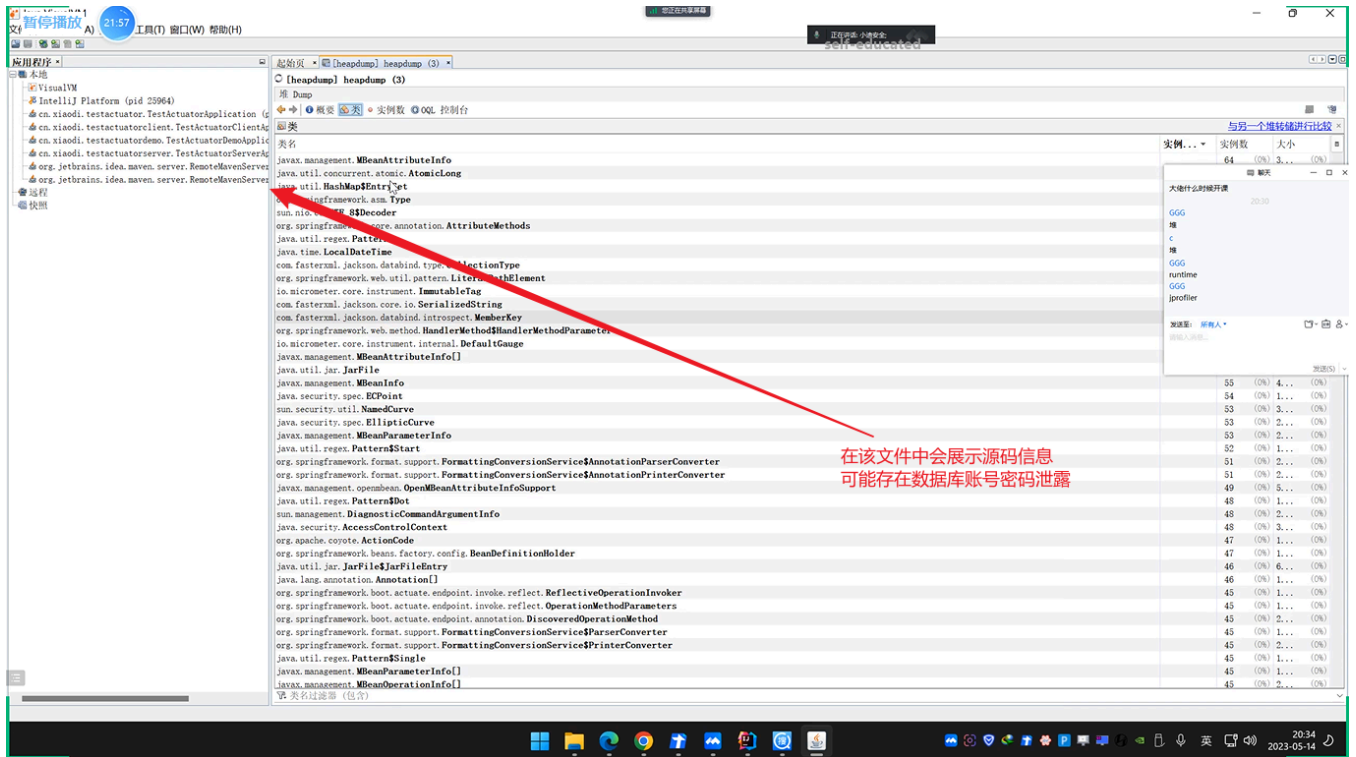
The screenshot shows the Spring Boot Admin web interface. On the left, a sidebar contains a menu with 'Insights' selected, and sub-items like '性能' (Performance), '环境' (Environment), '类' (Classes), '配置属性' (Configuration Properties), '计划任务' (Scheduled Tasks), '日志配置' (Log Configuration), 'JVM', '映射' (Mappings), and '缓存' (Caching). The main content area displays details for the application 'spring-boot-application' with ID '8457787aae8e'. It includes sections for '信息' (Information), '元数据' (Metadata), '健康' (Health), 'Instance' (with diskSpace and ping metrics), '进程' (Processes), and '线程' (Threads). A red box highlights the sidebar menu, and a red text label '图形化监控actuator' points to the 'Insights' section.

(3) 安全问题：

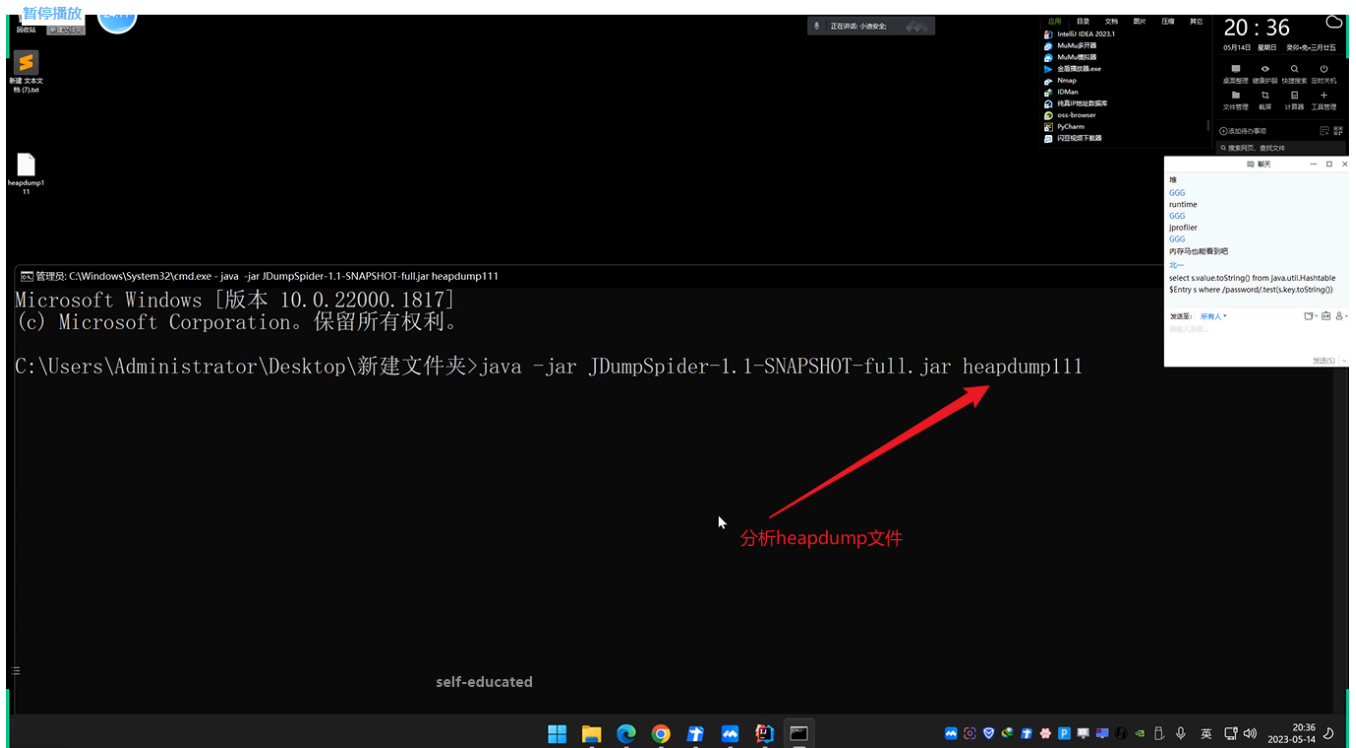
The screenshot shows a web browser displaying the Spring Boot Admin actuator endpoint. The browser's address bar shows 'localhost:8001/actuator/'. The page content displays a JSON response from the actuator, which includes various endpoints and their corresponding hrefs. A red arrow points to the 'href' field in the JSON response, which is 'http://localhost:8001/actuator/'. A red text label '其中访问actuator会出现href地址，访问不同的地址能得到不同的信息' (When accessing the actuator, the href address will appear, and accessing different addresses will provide different information) points to the href field.

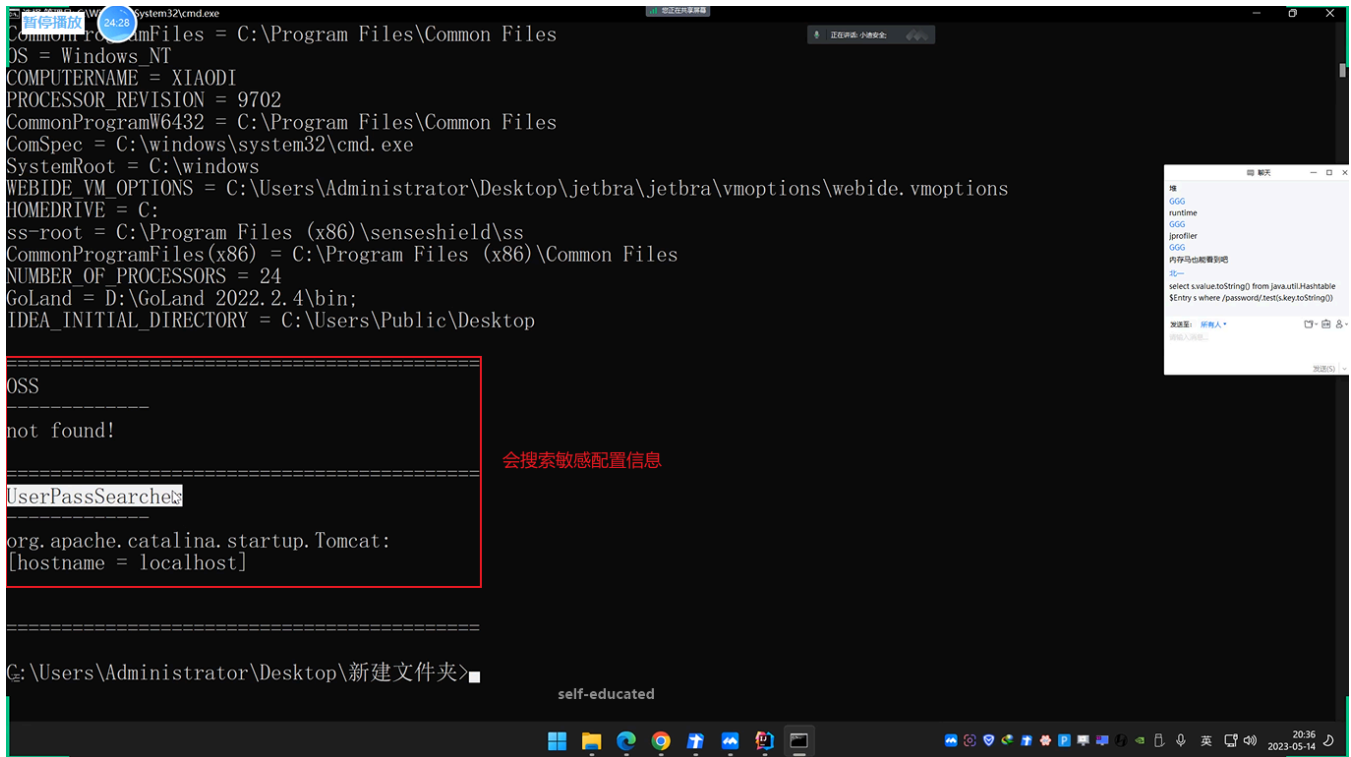


(4) jvisualvm分析器分析heapdump文件:



(5) JDumpSpider提取器提取敏感信息:





The screenshot shows a Windows command prompt window with the following text:

```
System32\cmd.exe
CommonProgramFiles = C:\Program Files\Common Files
OS = Windows_NT
COMPUTERNAME = XIAODI
PROCESSOR_REVISION = 9702
CommonProgramW6432 = C:\Program Files\Common Files
ComSpec = C:\windows\system32\cmd.exe
SystemRoot = C:\windows
WEBIDE_VM_OPTIONS = C:\Users\Administrator\Desktop\jetbra\jetbra\vmoptions\webide.vmoptions
HOMEDRIVE = C:
ss-root = C:\Program Files (x86)\senseshield\ss
CommonProgramFiles(x86) = C:\Program Files (x86)\Common Files
NUMBER_OF_PROCESSORS = 24
GoLand = D:\GoLand 2022.2.4\bin;
IDEA_INITIAL_DIRECTORY = C:\Users\Public\Desktop

=====
OSS
=====
not found!

=====
UserPassSearcher
=====
org.apache.catalina.startup.Tomcat:
[hostname = localhost]

=====

C:\Users\Administrator\Desktop\新建文件夹>
```

A red box highlights the search results for 'UserPassSearcher'. A red text label '会搜索敏感配置信息' (Will search for sensitive configuration information) points to the search results.

2.2 SpringBoot-接口系统-Swagger

- 1 **Swagger**是当下比较流行的实时接口文档生成工具。接口文档是当前前后端分离项目中必不可少的工具，在前后端开发之前，后端要先出接口文档，前端根据接口文档来进行项目的开发，双方开发结束后在进行联调测试。
- 2 参考：<https://blog.csdn.net/lisqingfeng/article/details/123678701>
- 3 -开发使用
- 4 1、引入依赖
- 5 <--2.9.2版本-->
- 6 <dependency>
- 7 <groupId>io.springfox</groupId>
- 8 <artifactId>springfox-swagger2</artifactId>
- 9 <version>2.9.2</version>
- 10 </dependency>
- 11 <dependency>
- 12 <groupId>io.springfox</groupId>
- 13 <artifactId>springfox-swagger-ui</artifactId>
- 14 <version>2.9.2</version>
- 15 </dependency>
- 16
- 17 <--3.0.0版本-->
- 18 <dependency>
- 19 <groupId>io.springfox</groupId>
- 20 <artifactId>springfox-boot-starter</artifactId>
- 21 <version>3.0.0</version>
- 22 </dependency>
- 23
- 24 2、配置访问
- 25 #application.properties


```
26 spring.mvc.pathmatch.matching-strategy=ant-path-matcher
27
28 #application.yml
29 spring
30   mvc:
31     pathmatch:
32       matching-strategy: ant_path_matcher
33
34 2.X版本启动需要注释@EnableSwagger2
35 3.X版本不需注释，写的话是@EnableOpenApi
36 2.X访问路径: http://ip:port/swagger-ui.html
37 3.X访问路径: http://ip:port/swagger-ui/index.html
38
39 3、安全问题
40 自动化测试: Postman
41 泄漏应用接口: 用户登录, 信息显示, 上传文件等
42 可用于对未授权访问, 信息泄漏, 文件上传等安全漏洞的测试.
```